

SKT 개인정보 유출 사고 원인 분석 및 대응 방안

박준혜 융합보안공학과 침해사고대응 개인 프로젝트

목차

- 0. 요약
- 1. 사고 및 배경
- 2. 대응 경과
- 3. 사고분석
- 3.1 공격 타임라인 및 침투 모델 분석
- 3.2 단계별 침투 경로 및 취약점
- 3.3 데이터 유출 및 영향
- 4. 대응 절차의 효율성 및 적절성 평가
- 4.1 탐지 및 초기 대응 단계의 비효율성
- 4.2 사고 인지 후 억제 및 복구 체제 비판
- 4.3 규제적 제재 및 피해 구제 절차의 한계
- 5. 기술적 통제 방안의 고도화의 필요성
- 5.1 제로 트러스트(Zero Trust) 아키텍처로의 전면 전환
- 5.2 핵심 데이터(Ki, IMSI)의 강력한 암호화 및 망 분리
- 6. 관리적 보안 거버넌스 개편
- 6.1 취약점 패치 관리 생애주기 의무화
- 6.2 침해사고 모니터링 가시성 확보 및 정기 모의 훈련
- 6.3 법적/제도적 컴플라이언스
- 7. 결론 및 시사점

0. 사고 및 배경

[분석 범위 및 한계]

본 보고서는 개인정보보호위원회, 과학기술정보통신부, 한국인터넷진흥원 및 SK텔레콤이 공개한 자료를 바탕으로 사고 경과와 원인을 분석하였다. 공개자료에서 확인되지 않은 최초 침투기법과 공격자 신원은 단정하지 않았으며, MITRE ATT&CK 분류는 공개된 공격 행위를 구조화하기 위한 분석 기준으로 활용하였다.

[사고 개요 및 규모]

본 보고서는 2025년 4월 발생한 SK텔레콤의 대규모 개인정보 유출 사고를 기술적, 관리적 관점에서 분석하였다. 사고로 인해 가입자 식별정보(IMS) 및 유심 인증키(Ki) 등 핵심 민감정보 약 2,696만건(9.82GB)이 유출되었으며, 이는 국내 통신업계 역사상 최대 침해사고로 기록되었다.

[핵심 원인 분석]

1. 관리적 실패: 2016년에 이미 경보가 발령된 OS취약점을 8년간 패치하지 않고 방치하였다.
2. 설계적 결함: 유심복제(SIM Swapping)를 막기 위한 최후의 보루인 인증키(Ki)를 암호화하지 않고 평문으로 관리하였다.
3. 운영적 태만: 서버 계정 정보를 평문으로 저장하여 해커에게 내부 망 마스터키를 제공한 셈이 되었으며, 이로 인해 약 3년 8개월간의 장기 체류(Dwell Time)를 허용하였다.

[대응 절차 평가]

사후 대응 과정에서도 결함이 발견되었다. 9.82GB의 막대한 데이터가 외부로 유출되는 동안 내부 관제 시스템은 단 한 차례의 이상 징후도 탐지하지 못했으며, 사고 인지 후에도 법정 통지 기한(72시간)을 넘겨 지연 통지함으로써 이용자의 2차 피해 가능성을 키웠다. 이에 대해 개인정보위원회는 약 1,348억 원이라는 역대 최대 규모의 과징금을 부과하였다.

[향후 재발 방지]

1. 기술적 측면: 기존 경계 기반 보안을 폐기하고 *제로 트러스트 아키텍처(ZTA) 도입 및 *저장 데이터 암호화, 전송구간 보호, HSM 기반 키 관리, 접근 권한 통제와 감사로그를 적용해야 한다.
2. 관리적 측면: 취약점 패치 관리 생애주기(VMLC)를 의무화하고, CPO의 독립적 권한을 보장하는 보안 거버넌스 개편이 필요하다.

*제로 트러스트 아키텍처: 신뢰할 수 있는 사용자인지 지속적으로 검증, 확인함으로써 위험을 완화하는 새로운 보안 프레임워크

* HSM: 암호키를 안전하게 생성·저장·관리하고 암호 연산을 수행하는 전용 보안 장치.¹

¹ TTA정보통신용어사전 <https://terms.tta.or.kr/main.do>

1. 사고 및 배경

2025년 4월 22일, 국내 대형 이동통신사인 SK텔레콤에서 약 2,696만 건에 달하는 가입자 유심 정보 및 개인정보가 외부로 유출되는 대규모 침해사고가 발생했다.

개인정보보호위원회의 조사 결과에 따르면, “이동통신 관련 핵심 네트워크·시스템에 대한 관리 소홀로 2,300여만 명의 주요 디지털 개인정보(USIM 정보 등) 유출” 되었다.²

인증키(Ki)도 유출되어 USIM 복제에 대한 사회적 우려가 컸으며, 조사 과정에서 “방화벽 설정 미흡으로 외부 침입 취약, 서버 계정정보(ID/PW) 관리 부실, 암호화 미실시, 악성 프로그램 방지 소홀 등” 보호법 위반사항이 확인되었다. ³

단순한 외부망 해킹이 아닌 내부 시스템 관리망의 고질적인 취약점이 장기간 방치되어 발생한 지능형 지속 위협(APT, Advanced Persistent Threat)으로 확인되었다. ⁴

유심 복제를 통한 2차 금융 피해 가능성까지 제기되며 사회적으로 큰 파장을 일으켰다. 이에 KB 라이프와 NH농협생명은 일시적으로 SKT 휴대전화 인증을 제한하기도 했다.⁵

2. 대응 경과

2025년 4월 22일 SK텔레콤 뉴스로 보도에 따르면, SK텔레콤은 2025년 4월 19일 오후 11시경, 악성코드로 인해 유심 관련 일부 정보가 유출된 것으로 의심되는 정황을 발견했다. 정확한 유출 원인과 규모 및 항목 등을 지속적으로 파악 중이며, 관련 법률에 따라 4월 20일(일) 한국인터넷진

- 19일 저녁 해커에 의한 악성코드로 유심관련 일부 정보 유출 정황
- 유출 사실 인지 후 신속 신고와 함께 악성코드 삭제 및 해킹 의심 장비 격리 조치...현재까지 확인된 해당 정보 악용사례 없어
- 불법 유심기변 및 비정상 인증 시도 차단 강화
- 추가 안전 조치 원하는 고객에게는 ‘유심보호서비스(무료)’ 가입 제공 중
- 재발방지 위해 보안 체계 강화하고, 고객정보 보호 방안 마련

² 개인정보보호위원회 (2025. 08. 28.). "개인정보위, 'SK텔레콤 개인정보 유출사고' 제재처분 의결 및 1348억 과징금 부과", 대한민국 정책브리핑. (유출 규모 및 사고 개요 인용)

³ 정유라, 「SK텔레콤, 유심 해킹사태 과징금 1347억...역대 최대 규모」, 『파이낸셜투데이』, 2025.08.28., <http://www.ftoday.co.kr/news/articleView.html?idxno=346732>

⁴ 과학기술정보통신부·한국인터넷진흥원(KISA) (2025. 05.). "SKT 침해사고 민관합동조사단 원인조사 결과 브리핑". (내부 관리망 취약점 및 APT 공격 형태 인용)

⁵ 오서영, 「[단독] KB·NH, SKT 인증 중단했다...유출 사고 후폭풍」, 『SBS Biz』, 2025.04.25., <https://biz.sbs.co.kr/article/20000230990>.

흥원(KISA)에 침해사고 사실을 즉시 신고했다고 발표했다.⁶

2025년 4월 23일 유심보호서비스 가입 안내를 위해 전 고객 대상 문자(MMS)를 발송하였다.

추가적인 안전 조치를 원하는 고객을 위해 T월드를 통해 유심보호서비스(무료)를 제공하고 있다고 발표하였다. 유심보호서비스는 타인이 고객의 유심 정보를 복제 또는 탈취하여 다른 기기에서 통신 서비스에 접속하는 것을 차단해 주는 서비스이다.⁷

2025년 4월 24일 유심보호서비스 가입 프로세스를 간소화하였다고 발표했다.

유심보호서비스에 가입할 경우 해외 부정사용을 막기 위해 로밍 사용이 제한되는데, 이로 인해

- 고객 혼선 및 불편 최소화하기 위해 유심보호서비스 가입 프로세스 간소화
- 114 고객센터 상담시간 연장하고 사이버 침해 사고 전담센터 24시간 운영
- 디지털 취약 고객에 직접 전화, 유심보호서비스 설명 및 가입 안내
- ‘MVNO 유심보호서비스’ 출시해 SKT 회선 알뜰폰 고객까지 가입기준 확대

여러 단계를 거쳐야 하는 불편함이 있었다.

8

2025년 4월 25일 유영상 CEO는 SK텔레콤이 악성코드로 인한 사이버 침해 사고 관련 고객들의 보안 우려를 해소하기 위해 오는 28일부터 유심 무료 교체를 포함, 한층 강화된 고객 정보 보호

- 유영상 CEO “고객 여러분과 사회에 진심으로 사과… 고객 보호 및 보안 체계 강화에 최선”
- 28일부터 전국 T월드매장, 공항로밍센터서 희망 고객 대상 유심 무료 교체서비스
- 이미 교체한 고객도 소급해 비용 지원… SKT망 알뜰폰 고객도 동일 적용 예정
- 비정상인증시도 차단(FDS) 지속 강화, ‘유심보호서비스’도 5월 업그레이드 예정

조치를 시행한다고 밝혔다⁹

⁶ SK텔레콤, 「SK텔레콤에서 알려드립니다」, 『SK텔레콤 뉴스룸』, 2025.04.22., <https://news.sktelecom.com/211423>.

⁷ SK텔레콤, 「유심보호서비스 관련 알려드립니다」, 『SK텔레콤 뉴스룸』, 2025.04.23., <https://news.sktelecom.com/211436>.

⁸ SK텔레콤 PR실, 「유심보호서비스 확대 관련 알려드립니다」, 『SK텔레콤 뉴스룸』, 2025.04.24., <https://news.sktelecom.com/211464>.

⁹ SK텔레콤 PR실, 「SKT, 사이버 침해 사고 불안 해소 위한 고객보호 조치 강화...유심 무료 교체 포함」, 『SK텔레콤 뉴스룸』, 2025.04.25., <https://news.sktelecom.com/211563>.

SK텔레콤 고객정보 보호조치 내역
(2025. 4. 24 기준)

조치사항	내 용	현 황
FDS Fraud Detection System	고객 유심 정보 악용을 막기 위한 보안 시스템 불법 유심 복제 혹은 비정상 인증 시도가 감지되면 바로 차단	· 감지 기준 범위 세밀화해 더 빠르고 정확하게 차단 · 부정 기변 여부 판단 기준 정교화해 불법 유심 기변 시도 차단
유심보호서비스 확대	고객 유심에 안심기능을 설정, 타인이 고객의 유심 정보를 복제 또는 탈취하여 다른 기기에서 통신 서비스에 접속하는 것을 차단	· 유심보호서비스 가입 프로세스 간소화 · 114 고객센터 상담시간 연장, 사이버 침해 사고 전담센터 24시간 운영 · 디지털 취약 고객에 직접 전화, 유심보호서비스 설명 및 가입 안내 · 'MVNO 유심보호서비스' 출시, SKT 회선 알뜰폰 고객까지 가입기준 확대
유심 무료교체	2025년 4월 18일 24시 기준 이동통신 가입자에 한해 고객당 1회 유심 무상교체	· 2025. 4. 28 오전 10시부터 별도 공지 시점까지 · 오프라인 티월드 매장(판매점 제외) 및 로밍 부스에서 진행

10

대응과정에서 위반사항이 존재한다.

SK텔레콤이 해킹 공격을 받은 사고의 최초 인지 시점은 고객 정보 탈취를 인지한 지난 19일보다 하루 빨랐고 사고 인지 24시간 이내에 신고해야 하는 규정을 위반하였다.

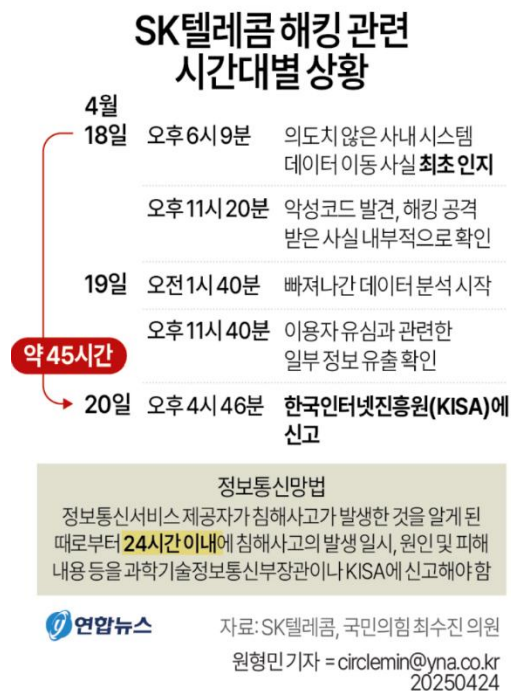
24일 국회 과학기술정보방송통신위원회 소속 최수진 의원(국민의 힘)이 SK텔레콤으로부터 제출 받은 자료에 따르면, SK텔레콤은 지난 18일 오후 6시 9분 의도치 않게 사내 시스템 데이터가 움직였다는 사실을 최초로 인지하였다. 오후 11시 20분 악성코드를 발견하고 해킹 공격을 받았다는 사실을 내부적으로 확인했고 다음날인 19일 오전 1시 40분 어떤 데이터가 빠져나갔는지 분석을 시작했다.

해킹 공격으로 판단한 18일 오후 11시 20분을 기준으로 하더라도 만 하루를 넘긴 시점에 신고했다.¹¹

정보통신망법은 정보통신서비스 제공자가 침해사고가 발생한 것을 알게 된 때로부터 24시간 이내에 침해사고의 발생 일시, 원인 및 피해 내용 등을 과학기술정보통신부장관이나 KISA에 신고해야 한다고 규정하고 있다.

¹¹ 조성미, 「SKT, 최초 이상 인지는 18일...24시간 내 해킹 보고 규정 위반(종합)」, 『연합뉴스』, 2025.04.24., <https://www.yna.co.kr/view/AKR20250424072451017>.

즉, SK텔레콤은 24시간 내 해킹 공격을 보고해야 하는 규정을 위반하였다.



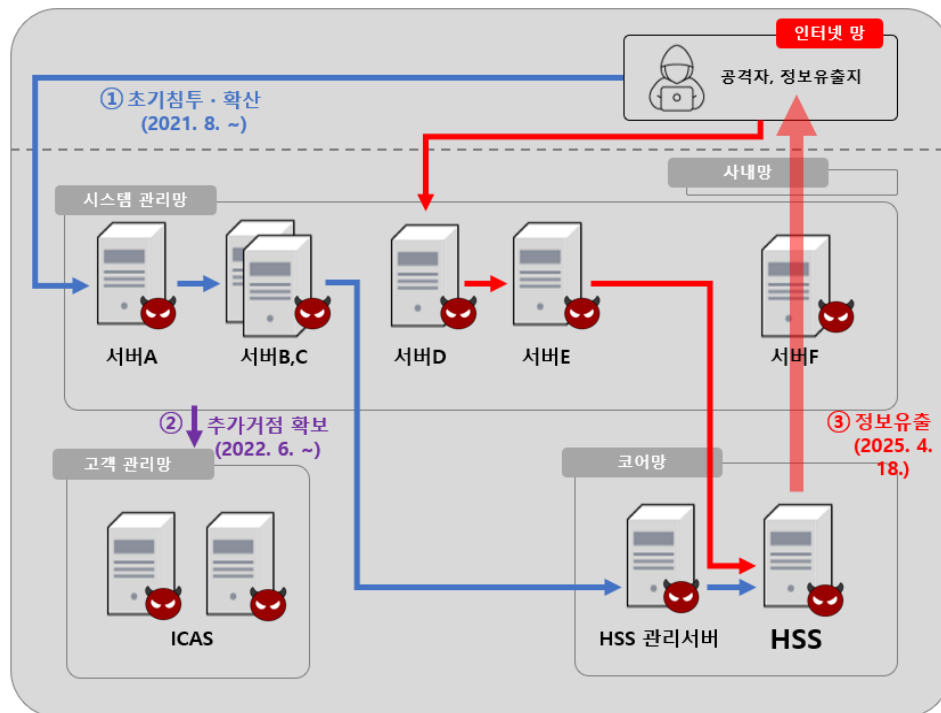
3. 사고분석

3.1 공격 타임라인 및 침투 모델 분석

2021년 8월 해커가 SKT 내부망에 최초 침투하여 다수 서버에 악성 프로그램을 설치하였다.

2022년 6월 ICAS(통합고객인증시스템)내 악성 프로그램을 설치하여 추가 거점을 확보하였다.

2025년 4월 18일 HSS(홈가입자서버) DB에 저장된 이용자의 개인정보(9.82GB)를 외부로 유출하



였다.

12

2025년 4월에 발생한 SKT 유심 정보 유출 사고를 MITRE ATT&CK 모델의 관점에서 분석했을 때, 2021년 8월 초기 침투를 시작으로 2025년 4월 정보가 유출될 때까지 약 3년 8개월이라는 장기간 동안 방어 시스템을 우회(Defense Evasion)하며 내부망에 은닉한 전형적인 지능형 지속 위협(APT, Advanced Persistent Threat)으로 분석할 수 있다. 공격자는 최초 침투 후에 즉각적인 데이터 유출을 시도하지 않고, 관리망 내부에 다수의 *백도어(Backdoor)를 설치하여 지속성을 확보하는 고도화 전력을 취한 것이다. 기존의 일회성 해킹 탐지 시나리오에만 의존하던 기존 보안 관제 시스템(SIEM)이 장기적인 이상 징후 식별을 실패한 것이다.

*MITRE ATT&CK 모델: 실제 데이터를 기반으로 하는 적대적인 전술 및 기술에 대한 전 세계적으로 접근 가능한 지식기반 모델

*백도어: 시스템 관리자나 개발자가 정상적인 절차를 우회하여 시스템에 출입할 수 있도록 임시로 만들어둔 출입문¹³

¹² 개인정보보호위원회 (2025. 08. 28.). "개인정보위, 'SK텔레콤 개인정보 유출사고' 제재처분 의결 및 1348억 과징금 부과", 대한민국 정책브리핑.(유출 관련 사실 관계 인용)

¹³ TTA정보통신용어사전 <https://terms.tta.or.kr/main.do>

공격 행위	ATT&CK 전술	분석 내용
악성코드 설치 후 장기 체류	Persistence	내부 시스템에 지속적인 접근 거점 확보
평문 계정정보 획득	Credential Access	내부 서버 접근에 필요한 인증정보 확보
관리망·고객망 서버 간 이동	Lateral Movement	탈취 계정을 이용해 침해 범위 확대
외부 C2 서버와 통신	Command and Control	감염 시스템에 대한 원격 통제 수행
가입자 정보 외부 반출	Exfiltration	핵심 개인정보와 인증정보 유출

위 분류는 공개된 공격 행위를 ATT&CK 전술 수준에서 분석한 결과이며, 공개자료만으로 확인하기 어려운 세부 Technique ID는 임의로 단정하지 않았다.

3.2 단계별 침투 경로 및 취약점

침투 경로는 초기 외부망 침투, 내부망 수평 이동, 핵심 DB 장악 및 유출의 3단계로 구분한다.

[초기 침투]

공격자는 외부 인터넷과 연결된 접점이 있는 시스템 관리망 내 서버에 접속하여 2021년 8월 6일 원격제어 및 백도어 기능을 수행하는 악성코드인 ‘CrossC2’를 최초로 설치하였다.¹⁴ 공격자는 외부와 연결된 접점 서버의 취약점을 악용하여 최초 접근 권한을 획득했다. 가장 치명적인 점은 이 최초 감염 서버에 시스템 관리망 내 다른 서버들이 계정 정보(ID, 비밀번호)가 암호화되지 않는 평문상태로 저장되어 있다는 것이다.¹⁵ 이는 내부망으로 들어가는 가장 강력한 문인 VPN에도 불구하고, 단일 인증 체계가 뚫린 이후 망 분리 예외 구간의 허점이 노출된 것이다.

[내부망 수평 이동]

탈취한 평문 계정 정보를 바탕으로 공격자는 내부망을 이동하기 시작했다. 공격자는 시스템 관리망 내 타 서버에 접속하여 코어망 내 ‘음성통화인증(HSS) 관리서버’의 평문 계정 정보까지 추가로 탈취하였다. 이를 통해 2021년 12월 24일 HSS 관리서버에 접속한 후 은닉형 악성코드인 ‘BPFDoor’를 설치하였다. 2022년 6월 15일과 22일에는 시스템 관리망을 넘어 고객 관리망 서버까지 진입하여 *웹셀과 BPFDoor를 설치하였다¹⁶. SKT는 시스템 관리망 내 서버의 계정 비밀번호

¹⁴ 과학기술정보통신부·한국인터넷진흥원(KISA) (2025. 05.). "SKT 침해사고 민관합동조사단 원인조사 결과 브리핑".(사고 원인 분석 인용)

¹⁵ 개인정보보호위원회 (2025. 08. 28.). "개인정보위, 'SK텔레콤 개인정보 유출사고' 제재처분 의결 및 1348억 과징금 부과", 대한민국 정책브리핑.(유출 관련 사실 관계 인용)

¹⁶ 과학기술정보통신부·한국인터넷진흥원(KISA) (2025. 05.). "SKT 침해사고 민관합동조사단

만료일을 설정하지 않아 공격자의 장기 체류를 허용한 것이다. 외부 접점을 통해 침투한 공격자는 인가된 사용자로 위장하여 시스템 관리망에 진입했다. 내부 방화벽의 느슨한 접근통제 정책(ACL)과 2016년 10월 이후 보안 패치가 전면 중단된 구형 운영체제(OS)를 방치한 관리적 허점을 악용하여, 시스템 관리망 내 핵심 서버 28대를 33종의 악성코드로 연쇄 감염시키는 데 성공했다. 내부망에 한 번 진입하면 모든 것을 신뢰하는 기존의 경계 기반 보안 아키텍처의 실패 사례이다.

*웹쉘: 업로드 취약점을 통하여 해커가 원격에서 웹서버를 조종할 수 있도록 작성한 웹 스크립트.¹⁷

[데이터 유출]

통신사는 가입자 인증을 위해 유심 인증키 (Ki)를 관리한다. 이는 탈취될 경우 유심 복제(SIM Swapping)로 직결되는 최고 등급의 민감정보이다. SKT는 통신망 인증의 핵심인 유심 인증키(Ki) 및 관련 가입자 식별 정보(IMSI)를 하드웨어 보안모듈(HSM) 등에 암호화하지 않고 평문 상태로 저장 및 관리하였으며, 이 아키텍처 결함이 약 2,700만 건이라는 대규모 유출의 직접적인 원인으로 작용하였다. 시스템 전반에 다중 거점을 확보하고 약 3년 8개월 간 은닉하던 공격자는 마침내 2025년 4월 18일, 음성통화인증 3개 서버에 저장된 9.82GB 분량의 유심정보(가입자 식별번호 IMSI 등 25종, 약 2,696만 건)를 시스템 관리망 내 외부 인터넷 연결 접점이 있는 서버(C)를 통해 최종적으로 외부로 반출하는 데 성공하였다.

3.3 데이터 유출 규모 및 영향

결과적으로 공격자는 장기간에 걸쳐 최대 9.7GB 분량의 압축된 가입자 데이터를 외부

*C&C(Command and Control) 서버로 유출했다. 이로 인해 휴대전화 번호, 단말기 고유 식별번호(IMEI), 유심 인증키 등 개인정보와 금융 인증의 기반이 되는 데이터가 노출되었으며, 기업은 개인정보보호위원회로부터 약 1,348억 원이라는 역대 최대 규모의 과징금을 부과받으며 심각한 재무적, 평판적 손실을 입게 되었다. 또한 2026년 4월 13일 법조계에 따르면 소비자원 소송지원 제도를 통해 SKT본사 소재지를 관할하는 서울중앙지법에 SKT를 상대로 1인당 위자료 10만 원을 청구하는 소송을 제기할 계획이라고 하였다¹⁸.

*C&C 서버: 좀비 PC를 조정하는 서버. 해커는 다른 사람의 PC를 악성코드로 감염한 뒤 C&C서버를 통해 각종 명령을 내린다.¹⁹

원인조사 결과 브리핑".(사고 원인 분석 인용)

¹⁷ TTA정보통신용어사전 <https://terms.tta.or.kr/main.do>

¹⁸ 심서현, 「SKT '유심 해킹' 결국 법정으로...피해자 50여명 집단소송 돌입」, 『뉴스1』, 2026.04.13., <https://www.news1.kr/economy/trend/6133273>.

¹⁹ TTA정보통신용어사전 <https://terms.tta.or.kr/main.do>

4. 대응 절차의 효율성 및 적절성 평가

본 보고서는 SK텔레콤의 대응체계를 예방, 탐지, 억제, 복구 및 이용자 통지 단계로 구분하여 평가하였다. 이를 통해 사고 발생 이후의 조치뿐만 아니라 사고 이전의 자산관리와 접근통제, 침해 징후 탐지, 고객 피해 예방 절차를 함께 검토하였다.

4.1 탐지 및 초기 대응 단계의 비효율성

사고 발생 전인 2022년경부터 유심 복제(SIM Swapping)와 관련된 보안 위협이 국내외 언론 및 보안 업계에서 지속적으로 제기되었음에도 불구하고 SKT는 선제적인 데이터(인증키) 암호화 조치나 내부 관리망의 전면적인 취약점 점검을 적시에 수행하지 않아 대규모 정보 유출을 사전에 차단할 수 있었던 골든타임을 상실했다. 특히, 과기정통부 조사 결과에 따르면 사고 당시 SKT는 부정사용방지시스템(FDS 1.0)과 유심보호서비스를 운영 중이었으나, 가입자가 약 5만 명에 불과해 대규모 침해사고로부터 안전한 통신 서비스를 제공해야 할 기업의 주된 보호 의무를 다하지 못한 것으로 드러났다. 이는 알려진 위협에 대한 위협평가가 실무에 즉각적으로 반영되지 않는 경직된 보안 거버넌스의 문제점을 보여준다.

4.2 사고 인지 후 억제 및 복구 체제 비판

2025년 4월 외부 기관(KISA 등)의 통보 혹은 뒤늦은 자체 인지로 해킹 정황을 파악한 직 후, SKT는 유심 재설정 솔루션을 도입하고 피해 고객에게 안내 문자를 발송하는 등 확산 방지 조치를 취했다. 표면적으로 이 사후 조치는 매뉴얼에 따라 수행된 것으로 보이나, 탐지 시스템 효율성은 처참한 수준이다 해커가 3년 8개월이라는 기간 동안 내부망에 침투하여 핵심 서버 28대를 악성코드로 감염시키고 9.82GB에 달하는 막대한 데이터를 외부 C&C서버로 반출하는 동안, 내부 통합 보안 관제 (SIEM)시스템과 침입 탐지 시스템(IDS)이 어떠한 이상 트래픽 유출 경고도 발생하지 못한 점은 대응 모니터링 절차의 총체적 부실과 심각한 비효율성을 보여준다.²⁰ 외부에서 들어오는 인바운드 트래픽 통제에만 치중하고, 내부에서 외부로 나가는 아웃바운드 데이터 유출에 대한 가시성을 확보하지 못한 것은 치명적인 기술적 대응 실패다.²¹

4.3규제적 제재 및 피해 구제 절차의 한계

사고 인지 이후의 대국민 소통 및 피해 구제 절차 역시 심각한 한계를 드러냈다. 개인정보보호위

²⁰ 과학기술정보통신부 (2025). 「SK텔레콤 침해사고 최종 조사결과 발표」. 보도자료 (2025. 7. 4.).

²¹ 개인정보보호위원회 (2025). 「'SK텔레콤 개인정보 유출사고' 제재처분 의결」. 보도자료 (2025. 8. 28.)

원회 조사 결과, SKT는 2025년 4월 19일 유출 사실을 인지했음에도 불구하고, 관련 법령이 규정한 '72시간 내 통지 의무'를 위반하고 5월 9일에야 유출 가능성만을 축소 통지하는 소극적 태도를 보였다. 실제 유출 통지는 7월 28일에야 이루어졌으며, 이는 정보주체의 2차 피해 예방을 어렵게 만들고 브랜드 불신을 초래했다. 결과적으로 개인정보보호위원회는 기업의 '안전조치 의무 위반'을 이유로 역대 최대 규모인 약 1,348억 원의 과징금과 960만원의 과태료를 부과하였다.²² 이를 통해 사고 인지 후의 기술적 복구를 넘어, 평상시의 보안 패치 관리와 암호화 조치 등 기본적인 대응 절차를 준수하지 않을 경우 기업이 부담해야 할 재무적 리스크가 얼마나 큰지 알 수 있다.

5. 기술적 통제 방안의 고도화의 필요성

확인된 문제	발생 가능한 위험	대응 방안
레거시 OS 장기 미패치	알려진 취약점을 통한 침투	자산 식별, 패치 우선순위 관리, EOS/EOL 시스템 교체
계정정보 평문 저장	계정 탈취 및 서버 간 이동	비밀관리시스템, 다중인증, 비밀번호 회전 정책
내부망의 폭넓은 신뢰	공격자의 수평 이동	최소권한, 마이크로 세그멘테이션, 세션별 재검증
핵심 인증정보 보호 미흡	유심 인증정보 노출	HSM 기반 키 관리, 저장·전송구간 암호화
아웃바운드 탐지 미흡	장기간 C2 통신 및 정보 반출	EDR·NDR·SIEM 연계와 이상행위 탐지

5.1 제로 트러스트(Zero Trust) 아키텍처로의 전면 전환

가장 시급한 과제는 '한 번 인증된 사용자는 신뢰한다'는 기존의 경계기반 보안 모델을 폐기해야 한다는 것이다. VPN을 통한 최초 접속이 허용되었더라도, 내부망 수평 이동시 단계별로 신원과 기기의 무결성을 지속적으로 검증하는 제로 트러스트 아키텍처를 도입해야 한다. 이를 통해 공격자가 시스템 관리망 내부로 침투하더라도 서버 간 통신을 세밀하게 통제하는 마이크로 세그멘테이션 기술을 통해 피해 확산을 원천 봉쇄할 수 있다²³.

²² 개인정보보호위원회 (2025. 08. 28.). "개인정보위, 'SK텔레콤 개인정보 유출사고' 제재처분 의결 및 1348억 과징금 부과", 대한민국 정책브리핑.

²³ NIST (National Institute of Standards and Technology). (2020). *Zero Trust Architecture*

5.2 핵심 데이터(Ki, IMSI)의 강력한 암호화 및 망 분리

통신 서비스의 핵심인 유심 인증키(Ki)와 가입자 식별 정보(IMSI)는 반드시 암호화되어야 한다. 데이터는 하드웨어 보안 모듈(HSM)에 보관하여 물리적, 논리적 접근을 통제하고, 데이터베이스(DB) 접근 시 종단간 암호화(E2EE, End-to-End Encryption)를 의무화하여 데이터가 외부로 유출되더라도 해독할 수 없도록 암호화 생애주기 관리를 강화해야 한다.²⁴

6. 관리적 보안 거버넌스 개편

6.1 취약점 패치 관리 생애주기 의무화

사고의 핵심 중 하나는 8년간 방치된 구형 운영체제(OS)였다. **기업은 IT 자산에 대한 철저한 식별을 바탕으로, 알려진 취약점(CVE)에 대한 보안 패치를 즉각적으로 적용하는 중앙집중형 패치 관리 시스템(PMS)을 강제해야 한다.** 특히, 패치 지원이 종료된 레거시 시스템(EOS/EOL)은 내부망과 물리적으로 완전히 분리되는 극단적인 격리정책이 수반되어야 한다.²⁵

6.2 침해사고 모니터링 가시성 확보 및 정기 모의 훈련

내부에서 외부로 나가는 아웃바운드 이상 트래픽을 탐지하지 못한 보안 관제 시스템의 문제점을 보완해야 한다. 인공지능 기반의 사용자 이상 행위 분석(UEBA) 및 보안 오케스트레이션 자동화(SOAR) 솔루션을 도입하여 관제 효율성과 대응 속도를 높여야 한다. 나아가, 실제 해커의 시각과 기법(TTPs)²⁶을 활용하여 내부망을 공격해 보는 레드팀 기반의 실전 모의훈련을 연 2회 이상 실시함으로써, 블루팀의 탐지 능력을 검증하고 침해 대응 매뉴얼의 실효성을 지속적으로 증명해야 한다.

탐지체계는 솔루션 도입뿐만 아니라 실제 탐지 대상과 로그 수집 범위를 구체적으로 정의해야 한다. 서버 간 비정상 인증 시도, 관리자 계정의 평소와 다른 접속, 장기간 반복되는 외부 C2 통신,

(NIST Special Publication 800-207). U.S. Department of Commerce.

CISA (Cybersecurity and Infrastructure Security Agency). (2023). *Zero Trust Maturity Model Version 2.0*. U.S. Department of Homeland Security.

²⁴ 한국인터넷진흥원(KISA). (2024). 「개인정보의 안전성 확보조치 기준 해설서」. 개인정보보호위원회.

²⁵ NIST. (2022). *Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology* (NIST Special Publication 800-40 Revision 4).

²⁶ MITRE Corporation. (2024). *MITRE ATT&CK® Framework*. Retrieved from <https://attack.mitre.org>

비정상 DNS 요청, 대용량 아웃바운드 트래픽 등을 주요 탐지 대상으로 설정할 수 있다. 또한 EDR, NDR, 방화벽과 인증 로그를 SIEM에서 연계 분석하고, 탐지 후 계정 잠금·호스트 격리·통신 차단 절차를 SOAR와 대응 매뉴얼에 반영해야 한다.

6.3 법적/제도적 컴플라이언스 강화

개인정보위원회의 시정명령에 따라 ²⁷핵심 코어망에 대한 ISMS-P 인증 취득이 의무화되었다. 기업은 단순한 인증용 보여주기식 보안을 넘어, 실질적인 위험 관리 체계가 작동하도록 최고 개인정보 책임자(CPO)의 독립적 권한을 강화하고 컴플라이언스를 내재화해야 한다.

7. 결론 및 시사점

SKT 침해사고는 고도화된 해커의 기술적 승리가 아니라, 8년간 방치된 구형 시스템과 평문 데이터가 초래한 관리적 보안의 실패이다. 기업은 보안을 비용이 아닌 핵심 생존 전략으로 인식하고 제로 트러스트 기반의 근본적인 개선에 나서야 한다.

참고문헌

개인정보보호위원회 (2025. 08. 28.). "개인정보위, 'SK텔레콤 개인정보 유출사고' 제재처분 의결 및 1348억 과징금 부과", 대한민국 정책브리핑. (유출 규모 및 사고 개요 인용)

정유라, 「SK텔레콤, 유심 해킹사태 과징금 1347억...역대 최대 규모」, 『파이낸셜투데이』, 2025.08.28., <http://www.ftoday.co.kr/news/articleView.html?idxno=346732>

과학기술정보통신부·한국인터넷진흥원(KISA) (2025. 05.). "SKT 침해사고 민관합동조사단 원인조사 결과 브리핑". (내부 관리망 취약점 및 APT 공격 형태 인용)

과학기술정보통신부·한국인터넷진흥원(KISA) (2025. 05.). "SKT 침해사고 민관합동조사단 원인조사 결과 브리핑". (사고 원인 분석 인용)

과학기술정보통신부 (2025). 「SK텔레콤 침해사고 최종 조사결과 발표」. 보도자료 (2025. 7. 4.).

개인정보보호위원회 (2025). 「'SK텔레콤 개인정보 유출사고' 제재처분 의결」. 보도자료 (2025. 8. 28.)

한국인터넷진흥원(KISA). (2024). 「개인정보의 안전성 확보조치 기준 해설서」. 개인정보보호위원회.

NIST (National Institute of Standards and Technology). (2020). Zero Trust Architecture (NIST

²⁷ 개인정보보호위원회. (2025). 「'SK텔레콤 개인정보 유출사고' 제재처분 의결」. 보도자료 (2025. 8. 28.).

Special Publication 800-207). U.S. Department of Commerce.

CISA (Cybersecurity and Infrastructure Security Agency). (2023). Zero Trust Maturity Model Version 2.0. U.S. Department of Homeland Security.

NIST. (2022). Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology (NIST Special Publication 800-40 Revision 4).

MITRE Corporation. (2024). MITRE ATT&CK® Framework. Retrieved from <https://attack.mitre.org>

오서영, 「[단독] KB·NH, SKT 인증 중단했다...유출 사고 후폭풍」, 『SBS Biz』, 2025.04.25., <https://biz.sbs.co.kr/article/20000230990>.

SK텔레콤, 「SK텔레콤에서 알려드립니다」, 『SK텔레콤 뉴스룸』, 2025.04.22., <https://news.sktelecom.com/211423>.

SK텔레콤, 「유심보호서비스 관련 알려드립니다」, 『SK텔레콤 뉴스룸』, 2025.04.23., <https://news.sktelecom.com/211436>

SK텔레콤 PR실, 「유심보호서비스 확대 관련 알려드립니다」, 『SK텔레콤 뉴스룸』, 2025.04.24., <https://news.sktelecom.com/211464>.

SK텔레콤 PR실, 「SKT, 사이버 침해 사고 불안 해소 위한 고객보호 조치 강화...유심 무료 교체 포함」, 『SK텔레콤 뉴스룸』, 2025.04.25., <https://news.sktelecom.com/211563>

조성미, 「SKT, 최초 이상 인지는 18일...24시간 내 해킹 보고 규정 위반(종합)」, 『연합뉴스』, 2025.04.24., <https://www.yna.co.kr/view/AKR20250424072451017>.

심서현, 「SKT '유심 해킹' 결국 법정으로...피해자 50여명 집단소송 돌입」, 『뉴스1』, 2026.04.13., <https://www.news1.kr/economy/trend/6133273>.

TTA정보통신용어사전 <https://terms.tta.or.kr/main.do>